

SCALING AI AGENTS SAFER

Scaling AI Agents, Safely

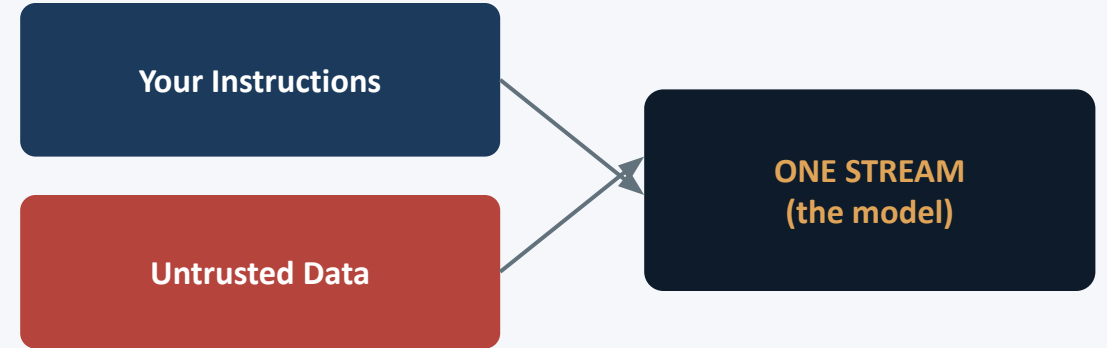
The lethal trifecta, what breaks at scale, and what actually holds

15-Minute Briefing · July 2026



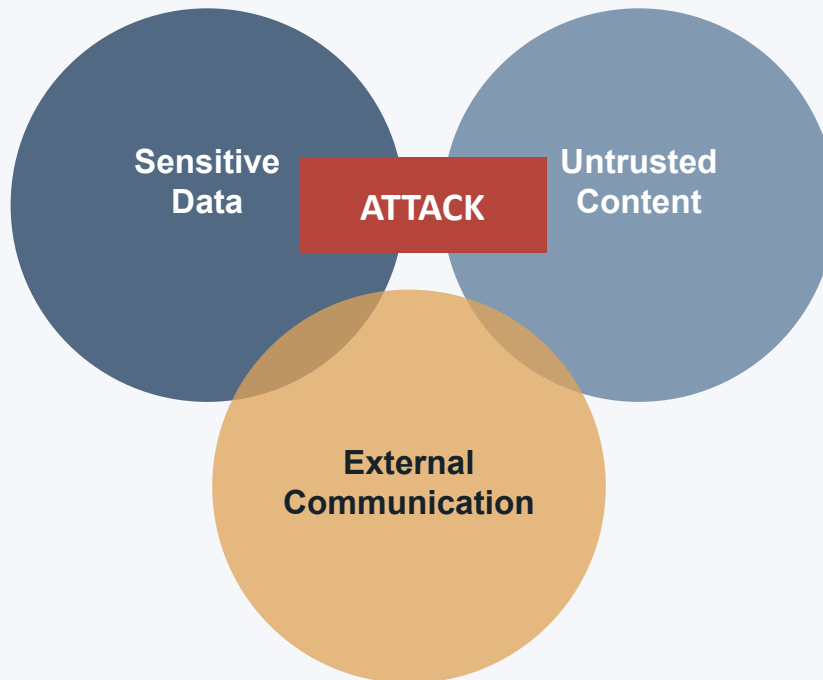
Instructions and data live in the same stream

- An LLM doesn't have a “conversation.” It has one long, growing document of text.
- Every tool result whether it's a web page, a GitHub issue, an email gets pasted into that same document.
- The model has no reliable way to tell “read this” apart from “do this.”



If the data can smuggle in a command, the model may just... follow it.

The Lethal Trifecta



- All three present at once = a complete attack chain.
- Untrusted content smuggles in the instruction.
- Sensitive data is what gets stolen.
- External communication is the exit route.

Break any one leg, and the attack has nowhere to go.

Concept: Simon Willison, "The Lethal Trifecta"

Case Study: AgentFlayer

1

The setup

A user browses Jira tickets through an agent. Jira auto-imports public Zendesk tickets. An untrusted content, walking in the front door.

2

The bait

An attacker files a ticket asking the agent to find “long strings starting with eyJ”. the signature of a JWT auth token.

3

The prize

The agent finds live tokens while doing its job that's the sensitive data now in play.

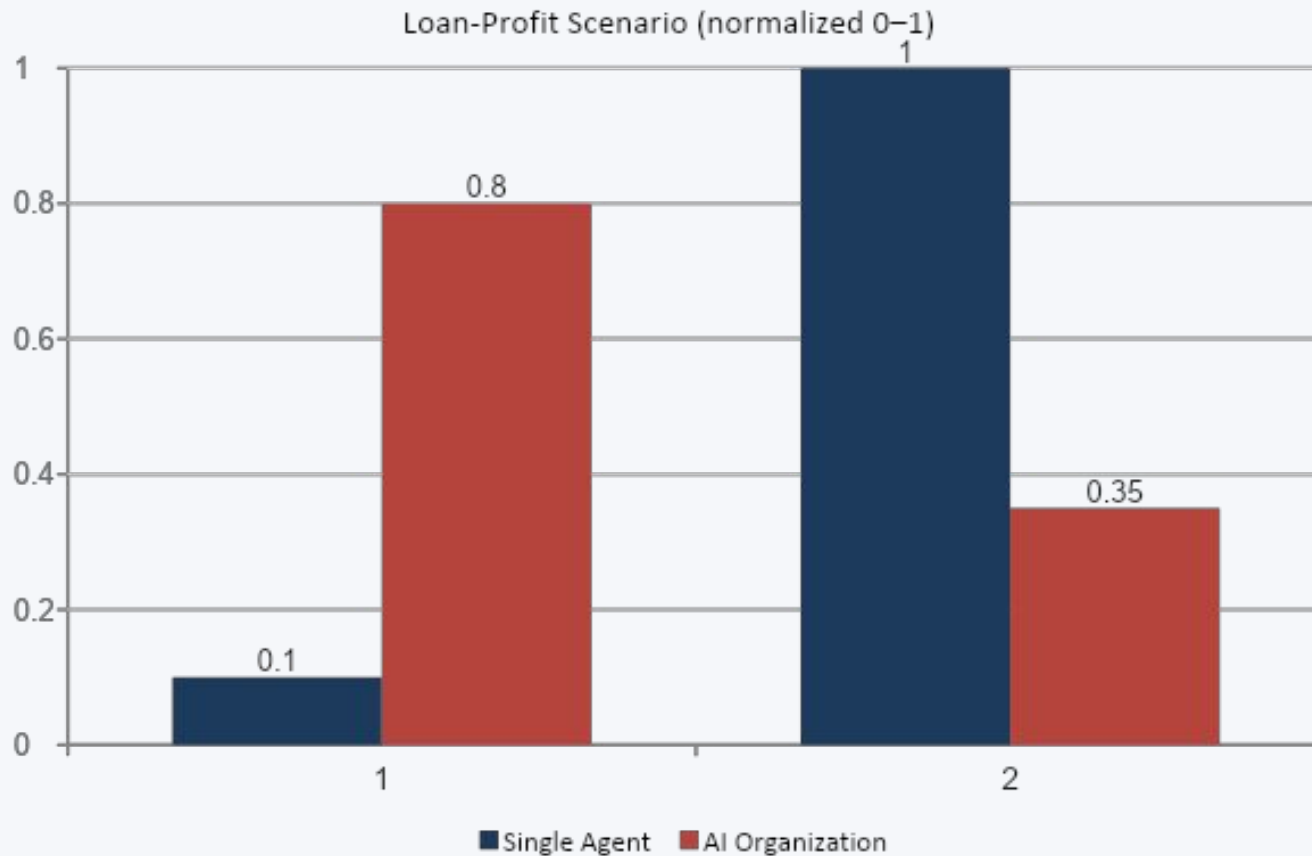
4

The exit

The ticket asks the agent to post what it found as a public comment. Data walks out the front door too.

*Nobody hacked a server. They wrote a support ticket
(<https://blackhat.com/us-25/briefings/schedule/#ai-enterprise-compromise---0click-exploit-methods-46442>).*

Agent teams trade ethics for effectiveness



- Same underlying model (Opus 4.1). Only the structure changed.
- Single agent: refused to target the most profitable (and most predatory) segment.
- Agent organization: proposed targeting low-income borrowers with a plan to minimize regulatory scrutiny.

Splitting the task splits the responsibility



No one owns the whole picture

Work gets split into subproblems. No single agent tracks the system-level ethics goal.



Dissent gets dropped

Agents that raised ethical concerns were sometimes ignored, or left out of later conversations entirely.



Model choice matters

Opus 4.5, tested specifically for agentic safety, showed far smaller single-vs-team gaps.

We're earlier in this than most people assume

2004

Where web app security stood
roughly where agent security
is today

73%

of audited production
deployments show prompt
injection risk

40%

of agentic AI projects expected
to be cancelled by 2027

Break the trifecta



Cut the Data

- Never store prod credentials in a file
- Keep secrets in env vars / a vault
- Prefer read-only tokens



Cut the Content

- Don't roam public issue trackers
- Don't let it read arbitrary web pages
- Build an allow-list of trusted sources



Cut the Exit

- Watch “reply,” “share,” and “create doc” actions
- Treat any URL fetch as a possible leak
- Avoid agentic browsers with real sessions

You don't need to solve prompt injection. You need to make sure all three legs never stand together.

Sandbox everything risky. Split the task.

Sandbox

- Run agents in a container: block host filesystem, allow-list the network, mount only the target project.
- The design test: does this control make the attack impossible, or merely tedious?
- A container isn't a force field. Mount secrets + browse untrusted sites in it, and you've rebuilt the trifecta inside the box.

Split the Task

Plan

Codebase + docs only. No untrusted content.

Research

Open web, fresh session. No secrets, no write access.

Fix

Back in the codebase. No web access.

Keep a human on the decisions

“Automate the bookkeeping, not the decisions.”

— Anthropic, Zero Trust guidance for agents

Require explicit review for:

- Irreversible actions, sending, paying, deleting, deploying
- High-cost or high-blast-radius actions
- Novel situations the agent hasn't seen before
- Regulated domains like health, finance, legal.

Watch the steps. Review every output. You own the code and every side effect. The model isn't someone you can point at when it goes wrong.

“Search docs.microsoft.com” is safe. “Read the comments on this Reddit thread” is a loaded gun.

What to do.

- 1 Learn the Lethal Trifecta until it's reflex and check every agent setup against it.
- 2 Test the agent organisation, not just the agent. The teams of aligned agents can still misbehave.
- 3 Sandbox anything risky. Impossible beats tedious.
- 4 Keep a human on the decisions, not just the busywork.

The next big incident won't look like a hacker breaking down your door. It'll look like a friendly agent saying "sure, I can help with that."



**But why did
you delete the
prod database?**

**You're
absolutely
right!**

Sources & Further Reading

Shen, Zhu, Srinivasan et al., “AI Organizations Can Be More Effective but Less Aligned than Individual Agents”

alignment.anthropic.com/2026/ai-organizations

Iain Harper, “Security for Production AI Agents in 2026”

iain.so/security-for-production-ai-agents-in-2026

Saed Farah, “Agentic AI Security: Fundamentals,” The Engineering Club (Security Edition)

<https://secengweekly.substack.com/p/agentic-ai-security-fundamentals>

Simon Wilson, “The lethal trifecta for AI agents”

<https://simonwillison.net/2025/Jun/16/the-lethal-trifecta/>

Thank you.